Independent Penetration Test — Executive Summary (Apr 2026)

Engagement summary

An independent testing firm conducted a grey-box penetration test of the cloud email encryption service between 6 April 2026 and 24 April 2026. The engagement covered the internet-facing encryption gateway and its SMTP listeners, the recipient portal including its authentication and session handling, the tenant administration plane and its API, and the key management plane's externally reachable interfaces. Testers were provided with tenant administrator credentials for two purpose-built tenants and with architecture documentation, but not with source code.

The engagement was scoped as an annual assurance activity and was conducted under a signed rules-of-engagement document. Testing was performed against a dedicated pre-production environment configured to match production, with a controlled subset of tests replayed against production under supervision.

Findings summary

Ref	Severity	Finding	Status
PT-2026-01	Medium	Recipient portal session cookie lacked the Secure attribute	Remediated and retested 21 Apr 2026
PT-2026-02	Medium	The administration API accepted oversized request parameter	Remediated and retested 22 Apr 2026
PT-2026-03	Low	Verbose error response on a malformed S/MIME certificate disclosed	Remediated and retested 21 Apr 2026
PT-2026-04	Low	Password reset response timing differed measurably between known	Remediated and retested 23 Apr 2026
PT-2026-05	Low	Content Security Policy on the portal permitted inline style	Remediated and retested 24 Apr 2026.
PT-2026-06	Low	One dependency in the gateway image was two patch releases behin	Remediated and retested 24 Apr 2026

Findings not identified

No critical or high-severity findings were identified. Specifically, the testers were unable to achieve cross-tenant access to message content, to recover plaintext message bodies from storage or from intercepted transport, to bypass the second-factor requirement on administrative sign-in, or to cause the policy engine to select a weaker delivery method than tenant policy permitted. Attempts to force fallback from enforced TLS to opportunistic TLS by manipulating partner-domain discovery were unsuccessful.

Remediation and retest

All six findings were remediated and retested within the engagement window; the testing firm issued a clean retest letter dated 28 April 2026. The two medium findings were fixed within seven and nine days of report respectively, inside the thirty-day internal target for medium severity. The

organisation's internal targets are seven days for critical, thirty days for high, ninety days for medium and best-effort for low, measured from report date to verified fix.

Availability of the full report

This executive summary may be shared with prospective customers on request. The full technical report, including reproduction steps and the retest letter, is released under a mutual non-disclosure agreement through the account team. The organisation does not release the full report without a non-disclosure agreement in place, because reproduction steps for a fixed finding remain useful to an attacker against unpatched forks and integrations.

Supply chain assurance

The engagement was complemented by the standing software supply chain controls: a signed CycloneDX software bill of materials is produced for every deployable artifact, dependency composition analysis runs on every change and nightly against the released set, and container images are scanned before promotion. The bill of materials for a given release is available to customers under non-disclosure and is the basis on which the organisation answers component-level vulnerability enquiries.